



400-650-7088

TongESB

V7. 1. 3. 0

安全加固配置说明

版本：7130A01

北京东方通科技股份有限公司

2025 年 08 月

声明

版权

Copyright ©2025北京东方通科技股份有限公司。保留所有权利。

版权声明

- 本文档的所有权和知识产权归属于北京东方通科技股份有限公司（以下简称“东方通”）或其关联公司所有。
- 除非另有明确约定，东方通不授予任何明示或暗示的许可或权利，使用者不得以任何方式将本文档中的任何内容用于商业目的。
- 东方通对本文档享有版权。本文档的所有内容，包括但不限于文字、图像、图表、图标、示意图、屏幕截图等，均受版权法和国际版权条约的保护。
- 未经东方通明确授权，任何人不得对本文档以任何形式复制、修改、传播、分发、展示或进行衍生创作。

商标声明

- 、TongTech 标识以及其他相关东方通图形、徽标、服务名称和商标（以下统称为“东方通商标”）是东方通或其关联公司的注册商标或商标。
- 未经东方通明确授权，任何人不得以任何方式使用、复制或展示东方通商标。此外，未经东方通事先书面同意，不得将东方通商标与其他商标、标识或徽标进行混淆、链接或结合使用。
- 除非另有明确约定，本商标声明不授予任何明示或暗示的许可或权利，对东方通商标的使用须获得东方通的明确授权。
- 本文档提及的所有其他商标、标识、徽标或产品名称均为其各自所有者的财产，并可能受其各自的商标法保护。

免责声明

请在使用东方通产品之前仔细阅读本免责声明，并根据自身情况判断是否继续使用。如有任何问题，请联系我们的客户支持团队。

- 本产品的使用是基于用户自己的判断和风险评估。本文档仅作为使用指导，不对使用本产品所产生的结果做任何明示或暗示的担保。
- 东方通不对用户未按照本文档中的指导正确使用东方通产品而导致的任何损失或损害承担责任；
- 本文档可能会包含第三方提供的内容、链接或资源，这些内容由第三方自行负责。东方通对于这些内容的准确性、完整性、合法性或可靠性不承担责任。用户在使用这些内容时应自行判断和承担风险。
- 由于产品版本升级或其他原因，本文档内容会不定期更新。东方通保留在不事先通知用户的情况下随时对文档进行修改、更新或中止的权利。

如需获取有关东方通产品的许可或使用权，请联系北京东方通科技股份有限公司或授权代理商。任何违反本声明的行为将受到适用法律的追究。

版本变更说明

手册版本	适用产品	更新内容	更新日期
V7130A01	7.1.3.0	无	2025/08/22
V7120A01	7.1.2.0	无	2025/05/20
V7120A01	7.1.0.0	无	2024/07/30
V7020A01	7.0.2.0	无	2023/12/12
V7010A01	7.0.1.0	新增安全加固配置说明手册。	2023/07/21

前言

本文档是产品的用户使用手册之一。

阅读前注意事项

通过阅读本文档，您确认并同意自行承担因未具备必要专业背景 and 知识而导致的任何风险或后果。在使用本文档中提供的信息和指南时，请始终谨慎，并在必要时寻求专业人士建议和指导。

- 适用对象

本文档主要适用于使用本产品的系统管理员阅读，部分内容同样适用于基于本产品进行应用开发或应用部署的人员阅读。

- 专业背景

本文内容可能涉及到操作系统、服务器硬件、网络等相关领域的知识。请确保您具备相关背景 and 知识，以便更好地理解 and 应用本手册的内容。

- 技能要求

为了能够充分理解 and 应用本文档的内容，建议您具备如下技能：

- 掌握 Linux 系统基本操作；
- 熟悉数据库（MySQL 等）。
- 安装产品。

- 术语和概念

本文档可能使用一些专业术语和概念。请确保您熟悉这些术语和概念，或者有能力查阅相关资料以便进一步理解。

- 实践经验

为了最大程度地受益于本文档，建议您具备一定的实践经验。这将帮助您更好地应用文档中的操作指南 and 建议。

请注意，本文档不适用于没有相关专业背景 and 知识的用户。

若您对本文档的内容 or 所需背景有任何疑问，请在使用之前咨询相关专业人士 or 寻求额外的支持。

用户手册集

为您提供的用户使用手册集包含如下文档：

编号	手册名称	说明
1	001_TongESB_V7.1.3.0 使用手册	提供TongESB安装及使用说明。
2	002_TongESB_V7.1.3.0 数据库服务化操作指导	详细介绍数据库服务化中创建、配置、部署、调用数据服务的详细操作。

编号	手册名称	说明
3	003_TongESB_V7.1.3.0 数据映射操作指导	详细介绍数据映射的详细操作。
4	004_TongESB_V7.1.3.0 EDI操作指导	详细介绍EDI的详细操作。
5	005_TongESB_V7.1.3.0 动态路由语法规则手册	提供API动态路由语法规则说明。
6	006_TongESB_V7.1.3.0 链路跟踪	提供链路跟踪的安装及配置。
7	007_TongESB_V7.1.3.0 安全加固配置说明	提供安全加固配置说明。
8	008_TongESB_V7.1.3.0 常见问题	提供常见问题的解决方案。

技术支持

东方通产品将为您提供全方位的技术支持，您可以通过以下方式获得技术支持：

- 网址：www.tongtech.com
- 电话：400-650-7088
- 邮箱：support@tongtech.com

您在取得技术支持时，请提供如下信息：

- 您的姓名
- 您的公司信息
- 您的联系方式
- 操作系统及其版本
- 产品版本号
- 日志等错误的详细信息

目录

声明	1
版本变更说明	2
前言	3
1. 自身安全配置项	6
1.1. 以普通用户安装本产品	6
1.2. 使用端口及防火墙开通策略	6
1.3. 修改默认登录密码	6
1.4. 修改密码长度和强度	6
1.5. 定期数据备份	6
1.6. 开启 csrf 保护	7
1.7. 设置redis密码	7
1.8. 开启防重放攻击	7
1.9. 设置登录密码连续错误次数	8
2. 应用安全	9
2.1. 配置流程流量控制策略	9
2.2. 运行时HTTPS访问	9
2.3. 配置黑名单策略	9
2.4. 配置白名单策略	9
2.5. 配置服务时间控制策略	10

1. 自身安全配置项

本章节主要介绍产品自身安全配置项，基本不影响应用，为建议配置项。

1.1. 以普通用户安装本产品

在 Linux 操作系统以普通用户安装并运行，避免采用 root 用户导致产品权限过大。

1.2. 使用端口及防火墙开通策略

防火墙设置基本原则：对外用户访问只暴露应用访问端口，其它端口为产品内部进程通信端口。只需对内放开，切勿对外暴露，以下列出需要对外暴露的接口。

服务程序	默认端口	端口作用	配置文件
访问管理中心	8093	访问管理相关功能后端默认接口	Manage/AccessManager/config/management.yml
管理中心	8080	管理中心界面访问端口	Manage/config/application.yml
运行时	8185	HTTP服务访问接口	Server/httpProxy/config/application.yml
运行时	9999	WS服务访问接口	Server/config/application.properties

1.3. 修改默认登录密码

系统默认密码过于简单，为避免被暴力破解，安装后需要修改admin和普通用户的默认密码。

如果系统已经使用简单默认密码创建了用户，对于已经创建的用户请及时修改密码。

1.4. 修改密码长度和强度

避免密码强度过弱，被穷举暴力破解，需要设置密码长度和复杂度校验规则，保证账户安全。

密码长度配置可选长度为8-16，建议将密码设置为16，避免暴力破解。

密码强度设置建议配置为大写字母、小写字母、特殊字符、数字。

1.5. 定期数据备份

定期进行数据备份操作，系统被攻击后数据被破坏导致系统宕机，可以及时进行数据恢复避免造成更大的损

失。

1.6. 开启 csrf 保护

产品的 csrf 保护默认开启，开启后管理中心可以抵御 csrf 攻击，通过配置文件进行修改启用状态。

配置文件说明，如下所示。

Manage/AccessManager/config/management.yml

```
http:  
  csrf: true
```

1.7. 设置redis密码

使用 redis 做缓存及配置中心，为了 redis 安全防止缓存数据及配置信息被篡改，可以对 redis 配置较为复杂的密码，然后通过配置文件设置密码。

配置文件说明，如下所示。

Manage/AccessManager/config/management.yml

```
redis:  
  password: 123456
```

Manage/config/application-release.yml

```
spring:  
  redis:  
    password: 123456
```

1.8. 开启防重放攻击

重放攻击(Replay Attacks)又称重播攻击、回放攻击，是指攻击者发送一个目的主机已接收过的包，来达到欺骗系统的目的，主要用于身份认证过程，破坏认证的正确性。

重放攻击可以由发起者，也可以由拦截并重发该数据的敌方进行。攻击者利用网络监听或者其他方式盗取认证凭据，之后再把它重新发给认证服务器。

重放攻击在任何网络通过过程中都可能发生，是计算机世界黑客常用的攻击方式之一，可以通过开启如下配置来防御该类型的攻击。

配置文件说明，如下所示。

Manage/AccessManager/config/management.yml

```
sign:  
  #是否启用
```

enabled: **true**

1.9. 设置登录密码连续错误次数

支持限制同一用户登录时连续输入错误密码的次数，防止暴力破解用户密码。

配置说明，如下所示。

Manage/AccessManager/config/management.yml

```
login:
  #错误次数
  incorrectCount: 5
  #多少时间内达到错误次数 秒
  limitTime: 300
  #锁定时间 秒
  lockTime: 300
```

2. 应用安全

以下为应用相关安全配置项，从安全角度需要开启，但开启后可能会影响到应用正常使用，请酌情考虑。

2.1. 配置流程流量控制策略

支持对流程配置流量控制策略，可以进入管理中心创建次数控制或单位时间的流量控制策略，然后将策略绑定到流程上实现对流程的流量控制，防止流程遭到恶意攻击。

* 策略类型: ☒ 次数控制 ☐ 流量控制

* 控制周期: ⑦

* 流控值: 次 ⑦

2.2. 运行时HTTPS访问

配置运行时为https访问。

2.3. 配置黑名单策略

为防止黑客恶意攻击流程提供了黑名单策略，必要时将指定的 IP 加黑名单策略并绑定到流程，实现对流程的保护。

基本信息

* 策略名称: ⑦

* 策略类型: ☒ IP控制 ☐ 时间控制

* 类型:

描述: 0/200 ⑦

策略列表

IP地址	应用名称	操作
127.0.0.1	请选择应用	操作

2.4. 配置白名单策略

为防止黑客恶意攻击流程提供了白名单策略，必要时将指定的IP加白名单策略并绑定到流程，实现对流程的保护。

基本信息

* 策略名称:

请输入策略名称

?

* 策略类型:

☒ IP控制

☐ 时间控制

* 类型:

允许

拒绝

描述:

请输入描述

0/200

?

策略列表

IP地址	应用名称	操作
127.0.0.1	请选择应用	

2.5. 配置服务时间控制策略

为防止黑客恶意攻击流程提供了访问时间控制策略，仅仅在规定的时段提供服务。

通过管理中心创建时间控制策略，并绑定到流程可实现对流程的保护。

* 策略名称:

请输入策略名称

?

* 策略类型:

☐ IP控制

☒ 时间控制

* 类型:

允许

拒绝

描述:

请输入描述

0/200

?

* 服务日期:

☒ 周日

☒ 周一

☒ 周二

☒ 周三

☒ 周四

☒ 周五

☒ 周六

服务时间:

🕒

00:00

至

23:59

